PRUEBA FINAL DE EVALUACIÓN

Bases de datos — Seguridad: vistas, usuarios y permisos en MariaDB

Alumno/a: _____

Fecha: _____

Calificacion: _____ / 10

Instrucciones generales

Esta prueba evalúa la implementación de niveles de acceso externos a una base de datos MariaDB usando vistas, usuarios y privilegios. Lee atentamente cada ejercicio antes de responder.

1. Ejecuta el script empresa_db_setup.sql y, a continuacion, empresa_db_ampliacion.sql antes de comenzar. El segundo script añade las tablas clientes, contratos y log_accesos necesarias para los ejercicios 3, 4 y 5.
2. Cada ejercicio indica las tablas o vistas sobre las que hay que trabajar y el perfil de usuario al que se le aplican los permisos.
3. Justifica brevemente cada decisión de seguridad cuando el enunciado lo pida (una o dos frases son suficientes).
4. No esta permitido el uso del usuario root ni de privilegios globales (*.*) salvo que el enunciado lo indique explícitamente.
5. La prueba tiene una duración máxima de 90 minutos y se puntúa sobre 100 puntos.

Ejercicio	Contenido evaluado	Pts.	Nota
Ejercicio 1	Vista multitabla + columna calculada	**20**	
Ejercicio 2	Usuario externo + SSL + limites	**15**	
Ejercicio 3	Perfil de solo lectura segmentada	**20**	
Ejercicio 4	Acceso a datos sensibles con GRANT de columna	**20**	
Ejercicio 5	Configuración completa de acceso + baja	**25**	
TOTAL		**100**	___

Ejercicio 1 20 pts	**Vista multitabla con columna calculada y seguridad** CREATE VIEW · JOIN · columna calculada · ocultar datos económicos	Puntos ____/ 20

Contexto

El director de Proyectos necesita un cuadro de mando que le muestre, por cada proyecto activo, el nombre del proyecto, el departamento responsable, el numero de empleados asignados, las horas totales comprometidas y el porcentaje de ejecución presupuestaria. Sin embargo, no debe tener acceso a los importes exactos de los contratos ni a los salarios de los empleados.

APARTADO A — 12 PUNTOS

Crea la vista v_cuadro_proyectos que incluya:

- nombre del proyecto
- nombre del departamento
- num_asignados: numero de empleados asignados al proyecto
- horas_totales: suma de horas de todos los empleados asignados
- pct_ejecucion: porcentaje calculado como (SUM(horas) / 1000) * 100, redondeado a 1 decimal (usa 1000 como capacidad máxima referencial)

Filtra solo proyectos con estado 'activo'. No incluyas ninguna columna de importes económicos.

APARTADO B — 8 PUNTOS

Crea el usuario dir_proyectos@localhost con contrasena 'DirProy#26!'. Concedele UNICAMENTE acceso de lectura a v_cuadro_proyectos y a la tabla proyectos. Verifica los permisos con SHOW GRANTS.

Importante: La vista no debe exponer ningún importe económico ni dato salarial. El acceso directo a las tablas empleados, nominas y contratos debe quedar fuera del alcance de dir_proyectos.

ESPACIO DE RESPUESTA

Ejercicio 2 15 pts	**Usuario externo con autenticacion reforzada y limites de recursos** CREATE USER · IDENTIFIED WITH · REQUIRE SSL · MAX_CONNECTIONS · PASSWORD EXPIRE	Puntos ____/ 15

Contexto

Una empresa auditora externa necesita acceder periódicamente a empresa_db desde su red corporativa (rango 172.20.0.0/16). Por política de seguridad, la conexión debe ser obligatoriamente cifrada, la contraseña debe caducar cada 90 días, y el usuario no puede abrir mas de 3 conexiones simultaneas ni ejecutar mas de 2000 consultas por hora.

APARTADO A — 10 PUNTOS

Crea el usuario auditor_externo@'172.20.%.%' con las siguientes características:

- Plugin de autenticacion: ed25519
- Contrasena inicial: 'AudExt#2026!'
- Conexion SSL obligatoria
- Caducidad de contraseña cada 90 dias
- Máximo 3 conexiones simultaneas y 2000 consultas por hora

APARTADO B — 5 PUNTOS

Concede a auditor_externo@'172.20.%.%' acceso de solo lectura a las tablas empleados, departamentos y proyectos de empresa_db. Justifica en un comentario SQL por que no se concede acceso a nominas ni a contratos.

ESPACIO DE RESPUESTA

Ejercicio 3
20 pts

Vista de log de accesos y perfil de solo lectura segmentada

CREATE VIEW · WHERE · GRANT sobre vista · restriccion de tabla · log_accesos

Puntos
____/ 20

Contexto

El responsable de seguridad necesita monitorizar los intentos de acceso denegados al sistema. Debe poder consultar el log_accesos pero solo ver las filas con resultado 'denegado', sin acceder a los registros de accesos correctos (que podrian revelar patrones de uso legitimo).

Contexto: La tabla log_accesos fue añadida por el script de ampliacion empresa_db_ampliacion.sql y contiene: id, usuario_bd, accion, tabla_afect, fecha_hora, ip_origen, resultado.

APARTADO A — 10 PUNTOS

Crea la vista v_accesos_denegados que muestre solo las columnas usuario_bd, accion, tabla_afect, fecha_hora e ip_origen de la tabla log_accesos, filtrando unicamente las filas donde resultado = 'denegado'. Ordena el resultado por fecha_hora DESC.

APARTADO B — 6 PUNTOS

Crea el usuario resp_seguridad@localhost con contraseña 'Seguridad#26!' y concedele:

- SELECT sobre v_accesos_denegados
- INSERT sobre log_accesos (para poder registrar nuevos eventos de auditoria)

Asegurate de que resp_seguridad NO tiene acceso directo de lectura a la tabla log_accesos completa.

APARTADO C — 4 PUNTOS

Explica brevemente (en forma de comentarios SQL) por que es mas seguro conceder acceso a la vista v_accesos_denegados en lugar de conceder SELECT directamente sobre log_accesos.

ESPACIO DE RESPUESTA

Ejercicio 4 20 pts	**Acceso granular a datos económicos sensibles** GRANT columna · REVOKE · contratos · clientes · minimo privilegio	Puntos ____/ 20

Contexto

El departamento de Administración gestiona los contratos con clientes. Los técnicos de administración deben poder ver y actualizar ciertos campos de contratos y clientes, pero los importes económicos (importe en contratos, limite_credito en clientes) son confidenciales y solo los puede ver el director financiero.

Contexto: Las tablas clientes y contratos fueron añadidas por el script de ampliación. La tabla clientes contiene: id, razon_social, cif, email, telefono, limite_credito, activo. La tabla contratos contiene: id, proyecto_id, cliente_id, fecha_inicio, fecha_fin, importe, estado.

APARTADO A — 12 PUNTOS

El usuario tecnico_admin@localhost ya existe. Concedele los siguientes permisos usando GRANT a nivel de columna donde corresponda:

6. SELECT sobre las columnas id, razon_social, cif, email, telefono, activo de clientes (sin limite_credito).
7. UPDATE sobre las columnas email y telefono de clientes.
8. SELECT sobre las columnas id, proyecto_id, cliente_id, fecha_inicio, fecha_fin, estado de contratos (sin importe).
9. UPDATE sobre la columna estado de contratos.

Importante: No uses CREATE VIEW para este ejercicio. El objetivo es practicar GRANT a nivel de columna directamente sobre las tablas.

APARTADO B — 8 PUNTOS

El tecnico_admin habia recibido erróneamente en el pasado GRANT ALL sobre la tabla nominas. Revoca todos sus permisos sobre nominas. Después, verifica con SHOW GRANTS que ya no tiene acceso a esa tabla.

Ademas, crea el usuario dir_financiero@localhost con contraseña 'DirFin#26!' y concedele SELECT sobre todas las columnas de clientes y contratos (acceso completo a los importes).

ESPACIO DE RESPUESTA

Ejercicio 5 25 pts	**Configuracion completa de acceso externo y gestión de baja** CREATE VIEW · CREATE USER · GRANT · REVOKE · WITH CHECK OPTION · ACCOUNT LOCK	Puntos ____/ 25

Contexto

La empresa integra un portal web externo que permite a los empleados consultar y actualizar su perfil personal. Ademas, un empleado del departamento de Proyectos (ID = 10, usuario proj_coordinator@localhost) causa baja voluntaria y hay que gestionar la desvinculación de forma segura.

APARTADO A — VISTA DEL PORTAL WEB — 8 PUNTOS

Crea la vista v_portal_empleado que exponga id, nombre, email, cargo y dept_id de la tabla empleados. Añade WITH CHECK OPTION. Esta vista sera la única interfaz de acceso para el portal web.

APARTADO B — USUARIO DEL PORTAL — 7 PUNTOS

Crea el usuario portal_web@'192.168.10.%' con contraseña 'Portal#2026!', REQUIRE SSL y maximo 50 conexiones simultaneas. Concedele:

- SELECT y UPDATE sobre v_portal_empleado.
- EXECUTE sobre el procedimiento empresa_db.actualizar_salario.

Asegurate de que portal_web no tiene ningún privilegio directo sobre la tabla base empleados.

APARTADO C — BAJA LABORAL SEGURA — 10 PUNTOS

Gestiona la baja de proj_coordinator@localhost en tres pasos:

10. Bloquea la cuenta inmediatamente (sin eliminarla).
11. Revoca todos sus privilegios sobre empresa_db.
12. Crea el usuario proj_coordinator_nuevo@localhost con contrasena 'NuevoCord#26!'. Concedele los mismos permisos operativos: SELECT, INSERT, UPDATE, DELETE sobre proyectos y asignaciones, y SELECT sobre v_directorio.

Contexto: El usuario proj_coordinator tenía los siguientes permisos antes de la baja: SELECT, INSERT, UPDATE, DELETE sobre empresa_db.proyectos; SELECT, INSERT, UPDATE, DELETE sobre empresa_db.asignaciones; SELECT sobre empresa_db.v_directorio.

ESPACIO DE RESPUESTA

Referencia rapida de sintaxis

Puedes consultar esta referencia durante la prueba.

```
-- CREATE USER
CREATE USER [IF NOT EXISTS] 'user'@'host'
    [IDENTIFIED WITH plugin BY 'pass' | IDENTIFIED BY 'pass']
    [REQUIRE SSL | X509 | NONE]
    [WITH MAX_USER_CONNECTIONS n  MAX_QUERIES_PER_HOUR n]
    [PASSWORD EXPIRE INTERVAL n DAY | NEVER]
    [ACCOUNT LOCK | UNLOCK];

-- CREATE VIEW
CREATE [OR REPLACE] VIEW nombre AS
    SELECT ... FROM ... [WHERE ...]
    [WITH CHECK OPTION];

-- GRANT
GRANT priv [(col,...)] [, ...] ON nivel TO 'user'@'host'
    [WITH GRANT OPTION];
-- nivel: *.*  |  bd.*  |  bd.tabla  |  bd.rutina

-- REVOKE
REVOKE priv ON nivel FROM 'user'@'host';
REVOKE ALL PRIVILEGES, GRANT OPTION FROM 'user'@'host';

-- Gestion de cuentas
ALTER USER 'user'@'host' ACCOUNT LOCK;
ALTER USER 'user'@'host' IDENTIFIED BY 'nueva_pass';
DROP USER [IF EXISTS] 'user'@'host';
SHOW GRANTS FOR 'user'@'host';
SHOW GRANTS;
```